

GSG-01

Security Guide

Plain-Language Security for Small Business

Everything a business owner needs to understand about cybersecurity — written in plain English, without the jargon. No IT background required.

WHY THIS GUIDE EXISTS

Most cybersecurity guidance is written for IT departments. This guide is written for **you** — the business owner, practice manager, or operations leader who needs to understand the risks your business faces and what to do about them, without becoming a security expert.

Security does not have to be complicated. The basics — done consistently — prevent the vast majority of incidents. This guide covers those basics in plain language, with practical steps you can take right now.

01 The Threats That Target Small Businesses

Phishing Emails

The most common way attackers get in. A phishing email looks legitimate — it might appear to come from your bank, your software provider, or even a colleague. It tricks the recipient into clicking a link, entering a password, or approving a payment. Business Email Compromise (BEC), where attackers impersonate an executive to request a wire transfer, costs small businesses billions annually.

Ransomware

Malicious software that locks you out of your own files and demands payment to restore access. Small businesses are frequent targets because they are less likely to have robust backups. Recovery without paying the ransom requires complete, tested backups — something many businesses lack.

Stolen Passwords

Attackers buy stolen username and password combinations from data breaches and try them on other services — your email, your banking, your cloud storage. Without a second verification step (like a code sent to your phone), one stolen password can unlock everything.

Insider Risk

Not all threats are external. A departing employee with lingering access, a contractor with more permissions than they need, or a well-meaning staff member who forwards client data to the wrong address can all cause serious harm.

Vendor Breaches

If your payroll provider, your IT company, or any software tool you use gets breached, your data may be exposed even if you did everything right. Your vendors' security is an extension of your own risk.

02 Eight Areas Every Business Needs to Protect

Your Physical Space

Locked server rooms, screen locks, visitor logs, and secure disposal of old equipment and documents. Attackers do not always come through the internet — physical access to your equipment is just as dangerous.

Who Can Access What

Every employee should have their own login. No one should have access to more than they need for their job. And when someone leaves, their access should be removed the same day.

Your Network and Devices

A business-grade firewall, separate guest Wi-Fi, up-to-date software, and proper remote access controls. Your network is the road everything travels on — it needs to be secured.

Your Business Information

Know what sensitive data you hold, where it is stored, and how it is protected. Encrypt laptops. Back up regularly. Test those backups. Have a plan for disposing of data you no longer need.

When Things Go Wrong

A written plan for what to do if you experience a cyberattack or data breach. Who to call. What not to do. How to contain the damage. Businesses with a plan recover faster and spend less.

Your Vendors and Software

Every outside company with access to your systems or data is an extension of your risk. Know who has access, review it regularly, and remove it when a relationship ends.

Your Team

Your employees are both your biggest vulnerability and your best defense. Regular awareness training, clear reporting processes, and a blame-free culture turn your team into a human firewall.

Cloud and Remote Work

Cloud tools and remote work introduce new risks. MFA on every account, a secure remote access solution, and clear rules for personal devices used for work are essential.

03 Five Things to Do This Week

Turn on two-step verification on your email

This one step prevents the majority of unauthorized account access. Enable it on Microsoft 365 or Google Workspace today — it takes about 10 minutes and is free.

Get a business password manager

Stop reusing passwords. A business password manager (Bitwarden Teams is a good starting point) gives every employee their own secure vault and ensures every account has a unique, strong password.

Back up your data — and test it

Make sure you have a recent backup stored somewhere other than your office (cloud backup works well). Then actually test that you can restore from it. Untested backups fail when you need them most.

Know who has access to what

Make a quick list of your key systems and who can log into them. Remove anyone who no longer needs access — including former employees and old vendors.

Tell your team what to watch for

Send a brief message reminding staff to be suspicious of unexpected emails, especially those asking for urgent action, money transfers, or login credentials. A heads-up costs nothing and pays dividends.

04 Building Good Habits Over Time**Review access quarterly**

Every three months, check who has access to your key systems and confirm it still makes sense. Remove anything that is no longer needed.

Keep your software updated

Enable automatic updates where possible. When updates are not automatic, check for them monthly. Outdated software is one of the most common ways attackers get in.

Run a security awareness refresher annually

Once a year, spend 30 minutes with your team reviewing the basics — what phishing looks like, how to report something suspicious, and your password requirements.

Test your backups regularly

Quarterly at minimum, try restoring a file from your backup. It should work. If it does not, that is something you want to know now — not during a crisis.

Repeat the assessment

The Green Security Group Assessment at greensecuritygroup.com takes about 15 minutes. Running it annually gives you a clear picture of where you stand and what has improved.

05 Free Resources to Get Started**Green Security Group — greensecuritygroup.com**

Start with the free Business Security Assessment to get a scored report across all eight areas. Download the Security Toolkit for policy templates, a 90-day action plan, and a risk tracking spreadsheet.

Canadian Centre for Cyber Security — cyber.gc.ca

Canada's national authority for cybersecurity guidance. Publishes practical resources specifically for small businesses.

CISA Small Business Resources — cisa.gov

The U.S. Cybersecurity and Infrastructure Security Agency offers free training materials, toolkits, and assessment guides for small businesses.

Have I Been Pwned — haveibeenpwned.com

Check whether any of your employee email addresses have appeared in a known data breach. Free for individual checks.

ABOUT THIS DOCUMENT

Developed with assistance from Claude (Anthropic) and reviewed by Paul Green, CISSP. All content reflects real-world security practice for small businesses.